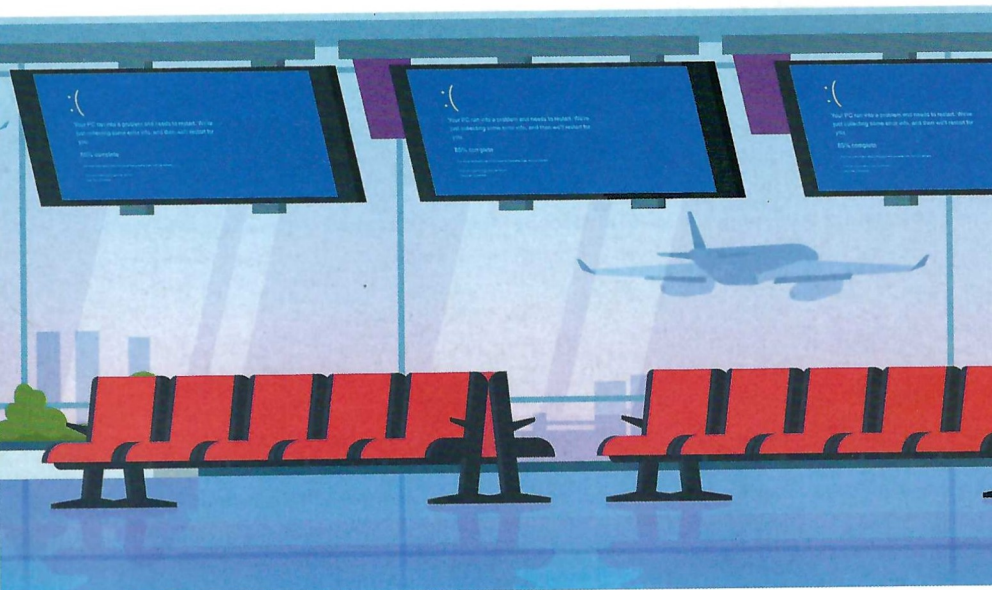




Ein Jahr danach: Lehren des CrowdStrike-GAUs

Ein defektes CrowdStrike-Update legte vergangenen Juli Millionen Windows-Systeme lahm. Wie es dazu kam und was sich in der IT-Welt seitdem gebessert hat.

Von Prof. Dr. Dennis-Kenji Kipker

■ Der 19. Juli 2024 dürfte sich so manchem Windows-Admin ins Gedächtnis gebrannt haben: Innerhalb weniger Stunden fielen rund 8,5 Millionen Windows-Geräte weltweit aus. Flughäfen, Bahnhöfe, Supermärkte, Kliniken, Ämter und Fernsehsender – überall konnte man Bluescreens auf den Displays bewundern. Die Folgen waren enorm, nicht nur Experten sprachen danach von einem IT-Super-GAU und Worst-Case-Szenario. Der Ausfall traf Unternehmen aus allen möglichen Branchen bis hin zu kritischen Infrastrukturen und der öffentlichen Verwaltung: Energieversorger, Transport und Verkehr, das Gesundheitswesen, Telekommunikation und die Wasserversorgung.

Laut einer Umfrage des Bitkom zusammen mit dem BSI musste fast die Hälfte der deutschen Unternehmen infolge des Vorfalles zeitweise ihren Betrieb einstellen. Ebenso mussten sich weltweit Regierungen mit der Frage auseinandersetzen, ob ihre kritische IT-Infrastruktur noch funktionsfähig ist.

Kleine Ursache, große Folgen

Wie so oft mittlerweile gingen die ersten Vermutungen an jenem schicksalsträchtigen Tag in Richtung eines Cyberangriffs. Das konnte jedoch schnell widerlegt werden, denn die globalen IT-Störungen eigneten sich nicht gleichzeitig von einer

Sekunde auf die andere, sondern bewegten sich Stück für Stück von einer Zeitzone zur nächsten. Zwangsläufig musste eine bestimmte operationalisierte Systematik dahinterstecken.

Diese Annahme bestätigte sich recht schnell, als das Cybersecurity-Unternehmen CrowdStrike erklärte, dass die weltweiten Ereignisse Folge der Verteilung einer fehlerhaften Channel-Datei seien. Sie aktualisierte die Detektionsregeln der Sicherheitssoftware Falcon.

Der eigentliche technische Fehler war banal: So waren nur diejenigen Systeme von dem IT-Ausfall betroffen, bei denen eine Channel-Datei mit einem bestimmten Zeitstempel installiert worden war. Aufgrund neuer Softwarefunktionen erwartete der Falcon-Sensor 20 Eingabefelder, während das fehlerhafte Channel-Update 21 Eingabefelder lieferte. In diesem Fall führte die Diskrepanz zu einem unzulässigen Speicherzugriff, der letztlich den massenhaften Systemabsturz zur Folge hatte.

CrowdStrike stellte recht schnell einen manuellen Workaround zur Löschung der fehlerhaften Channel-Datei bereit. Zumindest in Deutschland dauerte es im Schnitt zwei Tage, bis die Störungen vollständig behoben waren. Einige Unternehmen litten jedoch drei Tage und länger unter den unmittelbaren technischen Folgen. Oft mussten Admins mühsam jedes betroffene System einzeln anfassen. Am 25. Juli 2024 teilte CrowdStrike-Chef George Kurtz schließlich mit, dass über 97 Prozent der betroffenen Windows-Systeme wieder lauffähig seien.

Der wirtschaftliche Schaden war deutlich nachhaltiger als der eigentliche IT-Ausfall: Weltweit waren unterschiedlichste Unternehmen und Einrichtungen beeinträchtigt, Transport- und Lieferketten fielen in Teilen aus, Amtshandlungen konnten nicht durchgeführt werden. Gemeinhin wird angenommen, dass sich die kumulierten Schadenssummen im hohen Milliardenbereich bewegen müssen. Laut Schätzungen von Versicherungsgesellschaften haben die Ausfälle allein bei den 500 umsatzstärksten US-Unternehmen 5,4 Milliarden US-Dollar Kosten verursacht. Wenig verwunderlich, dass Fluggesellschaften wie die US-amerikanische Delta Air Lines schon kurze Zeit später Schadensersatzklagen gegen CrowdStrike und Microsoft vorbereiteten.

Mit Linux und macOS wäre das nicht passiert

In der IT-Community entfaltete sich eine intensive Debatte darüber, ob sich der

X-TRACT

- Ein eigentlich banaler Fehler in einem Update von CrowdStrikes Sicherheitssoftware Falcon war Ausgangspunkt eines globalen Massenausfalls.
- Das fehlerhafte Update konnte seine fatale Wirkung durch Kernelprivilegien für Sicherheitssoftware unter Windows entfalten, die Microsoft inzwischen beschränkt hat.
- Microsofts Quasimonopol bei Desktop-Systemen sorgt für ein Klumpenrisiko, das solche Massenausfälle begünstigt.

Vorfall auch auf Geräten mit alternativen Betriebssystemen hätte ereignen können. Linux- oder macOS-Systeme sollen nicht oder zumindest nur in einem geringen Ausmaß betroffen gewesen sein, obwohl Falcon für beide Betriebssysteme ebenso verfügbar ist. So stellte die British Computer Society (BCS) in einer Analyse fest, dass die Ansätze für den Kernelzugriff bei Windows, Linux und macOS deutliche Unterschiede aufweisen – und gerade Sicherheitsanbieter benötigen häufig den Zugriff auf die Kernelebene, um ein abnormales Systemverhalten besser erkennen zu können.

Wo Microsoft in der Vergangenheit einen recht umfassenden Kernelzugriff für Drittanbieter gewährte, verfolgen Linux und macOS den Walled-Garden-Ansatz. Er erlaubt einen restriktiven Zugriff nur für eine begrenzte Anzahl vertrauenswürdiger Module, sodass Sicherheitssoftware überwiegend im weniger privilegierten User Mode arbeitet. Die BCS gelangt in ihrer Analyse zu dem Schluss, dass der umfassende Kernelzugriff als Eigenart des Microsoft-Betriebssystems zum CrowdStrike-Vorfall führte, weil damit verbundene Systeminstabilitäten einen Absturz zur Folge hatten.

Das dürfte letztlich zum Umdenken bei Microsoft geführt haben. Wenn Sicherheitssoftware auf der vertrauenswürdigen Ebene von Windows ausgeführt wird, wo die Möglichkeiten zur Eindämmung und Wiederherstellung von Natur aus eingeschränkt sind, dann heißt das natürlich: Man muss sich für die Systemstabilität des eigenen Betriebssystems ganz erheblich auf die Fehlerfreiheit von Drittanbietersoftware verlassen können. Zu dieser Abwägung zwischen den Anforderungen der Sicherheitssoftware und dem Risiko des Kernbetriebs war Microsoft nach dem Debakel nicht mehr bereit und entschloss

sich daher Ende Juni, Sicherheitssoftware weitgehend aus dem Windows-Kernel zu verbannen, wie es das BSI bereits gefordert hatte.

Dazu kommen weitere Maßnahmen: Im Rahmen der Windows Resiliency Initiative hat man unter anderem den Boot-Prozess um die Quick Machine Recovery erweitert. Damit soll es zukünftig möglich sein, Windows-Systeme mit Boot-Problemen aus der Ferne wieder flottzubekommen. Und die Microsoft Virus Initiative verpflichtet Sicherheitsanbieter zu umfassenderen Tests und zum gestaffelten Verteilen ihrer Updates.

Klumpenrisiko Microsoft

Der globale IT-Super-GAU war im Ergebnis jedoch nicht nur eine Folge eines fehlerhaften Channel-Updates von CrowdStrike. Und auch die damit einhergehende und völlig berechtigte Forderung nach mehr Herstellerverantwortung, Qualitätssicherung und Security by Design bei laufzeit- und sicherheitssensitiver Software greift letztlich zu kurz. Denn zugleich muss man konstatieren, dass globale IT-Monopole einen nicht unerheblichen Einfluss auf den CrowdStrike-Ausfall gehabt haben dürften. Wenn nur macOS oder Linux anstelle von Microsoft Windows betroffen gewesen wären, wäre es aller Wahrscheinlichkeit nicht zu einem global flächendeckenden IT-Ausfall derartiger Intensität gekommen.

Dementsprechend hält auch der Chaos Computer Club die alleinige Kritik an CrowdStrike nicht für den richtigen Weg, das Geschehen aufzuarbeiten und die richtigen Schlüsse für mehr digitale Resilienz zu ziehen. Denn letztlich hat die betriebswirtschaftlich getriebene Konzentration auf wenige Anbieter ein Klumpenrisiko zur Folge: Wenn ein Fehler eine global eingesetzte IT-Architektur trifft,

dann wirkt sich dieser Fehler zwangsläufig global aus.

Fazit

Ein Jahr später – und um einiges an Wissen reicher – können und sollten wir uns die Frage stellen, was wir gelernt haben. Wo die allermeisten Menschen schon gar nicht mehr an das Ereignis denken, stehen IT-Sicherheitsverantwortliche vor der Frage, ob sich ein solcher Vorfall theoretisch jederzeit wieder ereignen könnte. Und definitiv dürfte die Antwort hier Ja sein.

So ist deutlich geworden, dass der Ausfall kritischer Infrastruktur und die Milliarden Schäden in der Wirtschaft die Folge dreier unglücklicher Ereignisse gewesen sind, die gleichzeitig zusammenkamen: ein fehlerhaftes Update und eine unzureichende Qualitätssicherung bei CrowdStrike, übermäßige technische Systemprivilegierungen für Sicherheitssoftware im Betriebssystem Windows und das kumulative IT-Risiko durch den Softwaremonopolisten Microsoft, von dem Millionen Unternehmen und Einrichtungen weltweit abhängig sind. Wir täten somit gut daran, an all diesen drei Faktoren intensiv zu arbeiten, um unsere weltweite IT-Infrastruktur nachhaltig resilienter aufzustellen. (axk@ix.de)

PROF. DR. DENNIS-KENJI KIPKER



ist Professor für IT-Sicherheitsrecht an der Hochschule Bremen und arbeitet dort an der Schnittstelle von Recht und Technik in der Informationssicherheit und im Datenschutz.